

감사결과 처분요구서

처분요구번호	2022-150	처분요구일자	2022. 12. 19.
처 분 종 류	개선		
관 계 부 서	○○○(주)		
제 목	접근권한 관리체계 개선 필요		

지 적 내 용

○○○(주)(이하 ‘회사’라 함)는 정보보안 관리체계의 수립과 시행에 필요한 사항을 「정보보안규정」(이하 ‘정보규정’이라 함)으로 제정('18.12.21.)하여 정보보안 관리 업무에 적용하고 있다.

특히 개인정보처리시스템에 대한 접근권한은 「개인정보보호법」 제29조¹⁾ 및 동법 시행령 제30조²⁾, 「개인정보의 안전성 확보조치 기준」(개인정보보호위원회 고시) 제5조³⁾에 따라 개인정보의 안전한 처리를 위해 접근권한 관리 지침을 수립·시행하도록 상세히 규정하고 있다.

1. 정보시스템 접근권한(계정) 관리 관련

公社는 상위기관 지침과 규정에 의거 정보보안활동에 필요한 세부사항을 「정보보안지침」으로 규정하여, 公社 및 ◇◇◇◇◇◇ 용역 대상으로 정보보안(사용자 계정관리 등)에 대한 종합 점검(년 1회)을 실시함으로써 사이버 침해사고를 사전에 예방하고 공항 운영의 안전성 확보 조치를 실시하고 있다.

1) 제29조 개인정보처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립, 접속기록 보관 등 대통령령으로 정하는 바에 따라 안전성 확보에 필요한 기술적·관리적 및 물리적 조치를 하여야 한다.

2) 제30조 제1항 제2호 개인정보에 대한 접근 통제 및 접근 권한의 제한 조치

3) 제5조 접근 권한의 관리

특히 정보시스템 계정 관리에 대한 보안의 중요성을 고려하여 상위기관 「정보보안규정」(국토교통부)에서는 정보시스템 사용자에게 소관 정보시스템의 접속에 필요한 사용자 계정(아이디)을 부여하고자 할 경우, 접근 권한 부여, 변경, 회수 또는 삭제 등에 대한 내역을 기록·보관하고, 사용자 계정 부여 및 관리의 적절성에 대한 점검 등을 수행 하도록 규정하고 있다.

그리고 정보시스템의 접근권한*(계정**) 관리를 소홀히(보직변경자 권한 유지, 사용자 계정 공동 사용, 장기간 미접속 사용자 계정 미관리 등) 했을 때, 주요 정보 탈취 및 시스템 장애를 유발할 수 있는 요인이 될 수 있으므로, 사용자 계정 관리는 불필요한 접근을 차단하기 위한 최소한의 정보보안 보호조치라 할 수 있다.

* 접근권한: 판독, 기록, 실행 등 디렉토리나 파일에 사용자가 접근·수행할 수 있는 작업 권한

** 계정:개인정보처리시스템에서 접속자를 식별할 수 있도록 부여된 ID 등 계정 정보

그러나 회사 정보규정에는 정보시스템 사용자 계정 관리에 대한 절차나 기준을 정하고 있지 않고, 계정 부여 및 삭제 등에 대한 기록, 보관 및 점검이 미흡하거나 이행되지 않고 있어, 상위기관 규정의 취지에 맞도록 계정 관리(사용자 계정 부여, 계정 삭제·회수 및 계정 점검·보관 등)에 대한 기준 조항도 포함시킬 필요성이 있다.

2. 개인정보처리시스템 접근권한 관리 관련

상위 법령에 의거하여 제정된 회사 「개인정보보호규정」(이하 ‘규정’이라 함)의 제29조 제7항에 따르면 분야별 책임관⁴⁾은 개인정보처리시스템에 대하여 개인정보의 분실·도난·유출·위조·변조 또는 훼손을 방지하기 위하여 접근권한(계정 포함)의 부여·변경·중지 등 관리절차를 명확히 하고, 중요도별 접근권한 통제 및 업무 외 불필요한 접근을 최소화 하도록 권한 관리 지침을 수립하여 운영하도록 기술하고 있다.

4) 개인정보 처리부서의 부서장

개인정보에 대한 모든 접근권한은 법령 또는 규정 등에 따라 허용된 자에 한하여 업무 수행에 필요한 최소한의 범위로 부여할 수 있도록 관리기준 수립, 관리책임자 지정 및 역할, 접근권한 관리절차 및 정기점검 등 관리 지침을 명문화하여 규정에 따라 개인정보의 안전성 확보조치를 이행하여야 한다.

그러나 회사는 인사정보를 처리하는 ERP시스템을 운영하고 있음에도 이에 대한 접근권한 관리 지침을 수립하지 않았고, 접근 권한의 관리, 접속기록의 보관 및 점검도 미흡하거나 이행되지 않고 있어, 관리 지침 수립을 통해 업무 목적 외 불필요한 접근 통제 등 관리·점검을 강화해야 한다.

관계부서 및 해당부서 의견

○○○(주)는 개인정보보호 서약서 징구와 사용자 관리를 통해 업무 차질을 최소화하기 위해서 노력하고 있으나, 향후 개인정보의 안전한 처리 및 정보보안을 위하여 ERP시스템의 접근권한 관리 지침을 수립하는 등 개인정보 안전성에 만전을 기하겠다는 의견을 제시하였다.

조치할 사항

○○○(주) 대표이사(★★★그룹장)는 정보시스템 계정관리에 대한 절차와 기준을 명확히 하도록 「정보보안규정」을 개정하고, 개인정보처리시스템에 대한 접근권한 관리 지침을 수립하여 접근권한(계정) 통제관리를 철저히 하시기 바랍니다. (개선)

인천국제공항공사 상임감사위원

직 인 생 략